



UNIVERSITÀ DEGLI STUDI DI MILANO



## Password cracking - John the ripper

Andrea Monzani, Danilo Bruschi

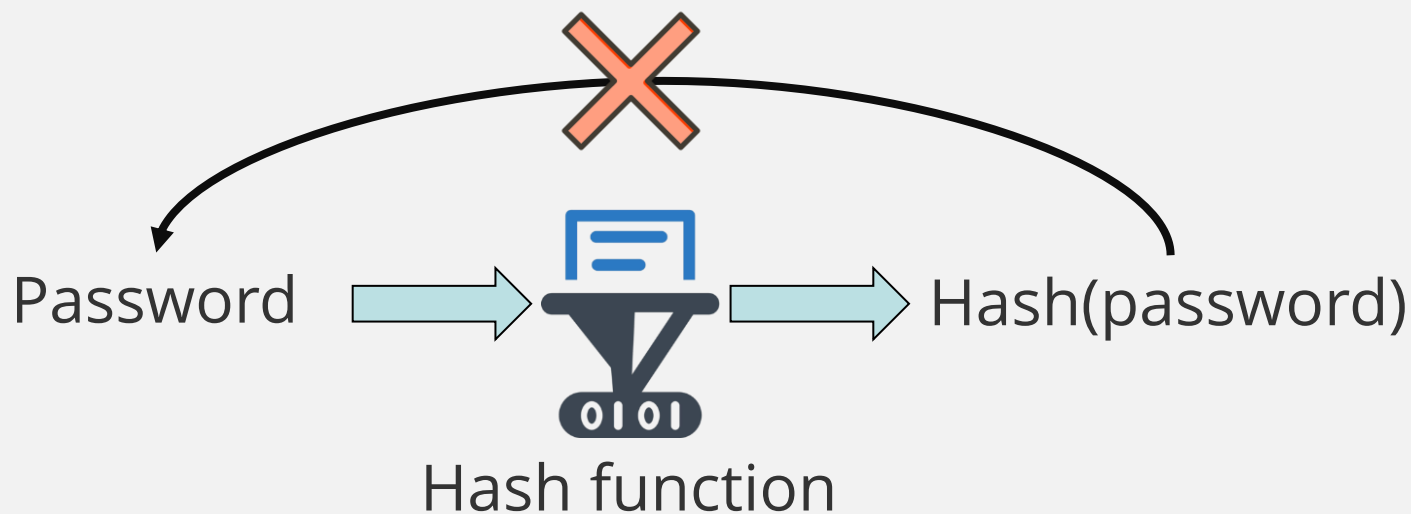
Laser, Computer Security lab.

Dipartimento di Informatica

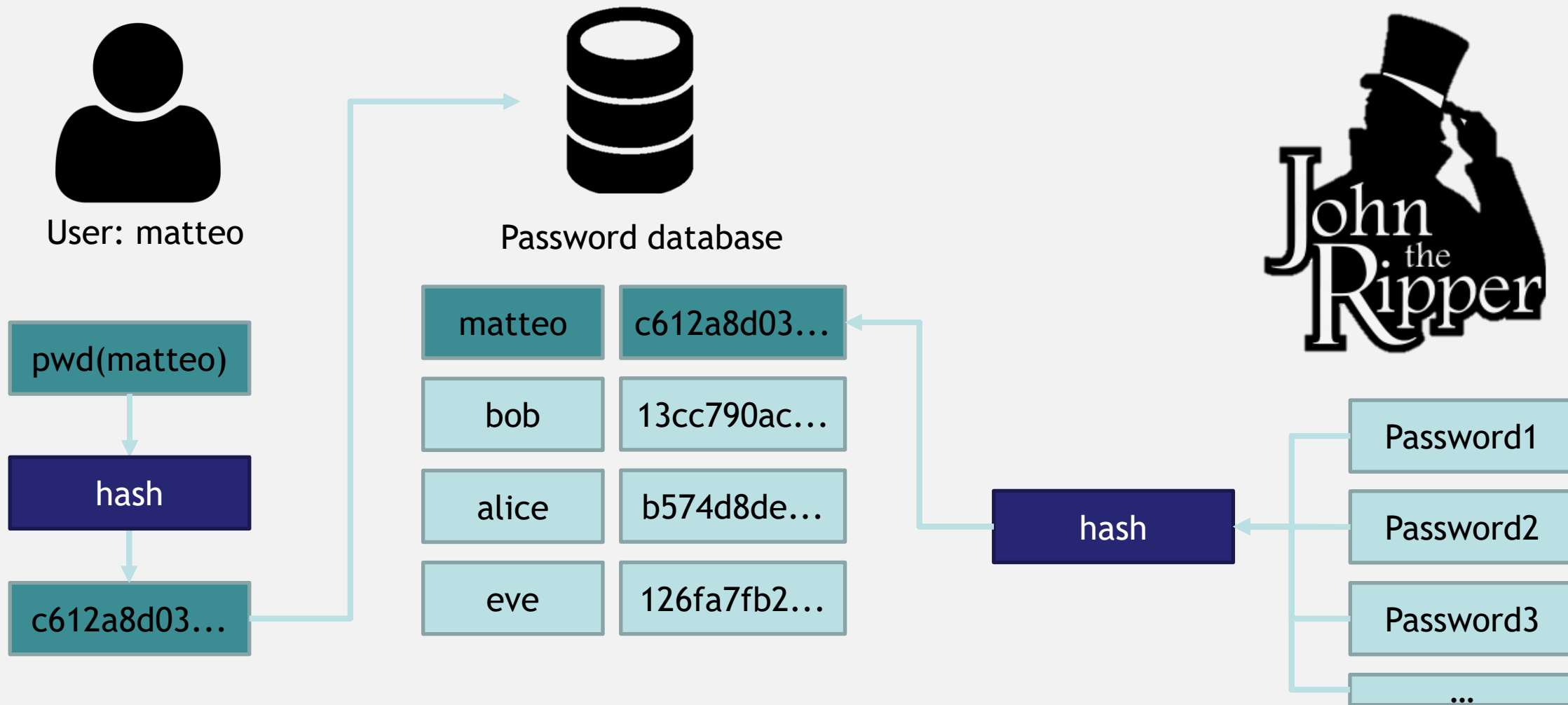
Università degli Studi di Milano

28 aprile 2025

- Leaked passwords can be “easily” found online
  - Data breaches, leaked files, misconfigured servers, ecc
  - <https://haveibeenpwned.com/>
- A leaked password is not usually in the cleartext form – it's *hashed*



# John the ripper



- John the Ripper is a free password cracking software tool.
- One of the most frequently used password testing and breaking programs as it combines a number of password crackers into one package, autodetects password hash types, and includes a customizable cracker.
- It can be run against various encrypted password formats, including several password hash types most commonly found on various Linux distributions and Windows.



# Simple hash cracking



Utente1:ec9e83f592aae13754352b802268b7defbdc5c246ad6c575bb2ee57a7f56ca46

Utente2:4be172b5c76a3f1285eb7cd91ffe8437eae2793a72f785e59f2693aa939b8fac

Utente3:ec9e83f592aae13754352b802268b7defbdc5c246ad6c575bb2ee57a7f56ca46

1. Identify the hash “type” using [hash-identifier](#)
2. Call [john the ripper](#) with the parameter [--format](#)

Password Utente1: [harper9](#)

Password Utente2: [12388km](#)

- **Single:** it use the login names, "GECOS" / "Full Name" fields, and users' home directory names as candidate passwords with a large set of mangling rules applied.
- **Wordlist:** simplest cracking mode, John try to hash all word specified in a wordlist file (a text file containing one word per line) also called dictionary and check if the password hash matches.
- **Incremental/Bruteforce:** this is the most powerful cracking mode, it can try all possible character combinations as passwords. However, it is assumed that cracking with this mode will never terminate because of the number of combinations being too large.

- **Rainbow table:** makes the exploitation of unsalted passwords easier. A rainbow table is essentially a **pre-computed database of hashes**. Dictionaries and random strings are run through a selected hash function, and the input/hash mapping is stored in a table.
- **External**

- With rainbow tables, the attacker can simply do a password **reverse lookup** by using the hashes from a stolen password database.
- The main difference between a rainbow table attack and a dictionary and brute-force attack is pre-computation. Rainbow table attacks are fast because the attacker **doesn't have to spend any time computing any hashes**.
- The trade-off for the speed gained is the **immense amount of space required** to host a rainbow table



- With rainbow tables, the attacker can simply do a password **reverse lookup** by using the hashes from a stolen password database.
- The main difference between a rainbow table attack and a dictionary and brute-force attack is pre-computation. Rainbow table attacks are fast because the attacker **doesn't have to spend any time computing any hashes**.

alice: 4420d1918bbcf7686defdf9560bb5087d20076de5f77b7cb4c3b40bf46ec428b  
jason: 695ddccd984217fe8d79858dc485b67d66489145afa78e8b27c1451b27cc7a2b  
mario: cd5cb49b8b62fb8dca38ff2503798eae71bfb87b0ce3210cf0acac43a3f2883c  
teresa: 73fb51a0c9be7d988355706b18374e775b18707a8a03f7a61198eefc64b409e8  
bob: 4420d1918bbcf7686defdf9560bb5087d20076de5f77b7cb4c3b40bf46ec428b  
mike: 77b177de23f81d37b5b4495046b227befa4546db63cfe6fe541fc4c3cd216eb9

- To mitigate the damage that a rainbow table, we salt the passwords. According to OWASP Guideliness, a salt is a fixed-length cryptographically-strong **random value** that is added to the input of hash functions to create unique hashes for every input.

|          |  |  |  |  |
|----------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| Password | p4s5w3rdz                                                                           | p4s5w3rdz                                                                           | p4s5w3rdz                                                                           | p4s5w3rdz                                                                           |
| Salt     | -                                                                                   | -                                                                                   | et52ed                                                                              | ye5sf8                                                                              |
| Hash     | f4c31aa                                                                             | f4c31aa                                                                             | 1vn49sa                                                                             | z32i6t0                                                                             |

- Traditional Unix systems keep user account information, including one-way encrypted passwords, in a text file called `/etc/passwd`. As this file is used by many tools (such as `ls`) to display file ownerships, etc. by matching user ids with the usernames, the file needs to be world-readable.
- `/etc/shadow` is a text file that contains information about the system's users' passwords as well as other information such as account or password expiration values etc. The `/etc/shadow` file is readable only by the root account (owned by user root and group shadow, 640 permissions) and is therefore less of a security risk.

```
madam:$6$reRr06Pic/lkDt1E$6B8znS3dxYmn95oeJmWxjlUdjVvVfcfjKmqTkNATyixayvLrXbxFps2NCoe3T  
FvSsLq8A8SwbE5m7QTGXY/1a.:1003:1003:Adam  
Miller:/home/madam:/bin/shjohn:$6$y/eK3qRBV1gTKB41$A0jR1C4lJh7cHv84xhHHWuwx2JvSpOKCA3  
8NnO8YNmNe3HDgthIVdifPvWO4NblUFPctY5L4vqGNQ6HBlhIBm.:1004:1004:John  
Doe:/home/john:/bin/sh
```

(Example of an old /etc/passwd linux file that contained also the passwords)

`$id$salt$hashed`

`id` identifies the hashing method used instead of DES and this then determines how the rest of the password string is interpreted.

The following values of `id` are supported:

| ID | Method |
|----|--------|
|----|--------|

|   |     |
|---|-----|
| 1 | MD5 |
|---|-----|

|    |                                                                     |
|----|---------------------------------------------------------------------|
| 2a | Blowfish (not in mainline glibc; added in some Linux distributions) |
|----|---------------------------------------------------------------------|

|   |                           |
|---|---------------------------|
| 5 | SHA-256 (since glibc 2.7) |
|---|---------------------------|

|   |                           |
|---|---------------------------|
| 6 | SHA-512 (since glibc 2.7) |
|---|---------------------------|

Thus, `$5$salt$hashed` and `$6$salt$hashed` contain the password hashed with, respectively, functions based on SHA-256 and SHA-512.

[crypt\(3\) - Linux manual page](#)

- <https://countuponsecurity.files.wordpress.com/2016/09/jtr-cheat-sheet.pdf>
- <https://www.openwall.com/john/doc/MODES.shtml>
- [https://cheatsheetseries.owasp.org/cheatsheets/Password\\_Storage\\_Cheat\\_Sheet.html#Use\\_a\\_cryptographically\\_strong\\_credential-specific\\_salt](https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html#Use_a_cryptographically_strong_credential-specific_salt)